

Use Case 기반 AI RMF Profile

4. Use Case 정의

4.1 정상 시나리오

사용자가 AI assistant에게 다음 작업을 요청한다.

“메일함에서 특정 메일은 찾아 요약하고, 그 내용은 캘린더에 등록해줘.”

AI assistant는 다음 작업을 수행한다.

Prompt/Context
Model
Calendar action

4.2 공격 시나리오

검색된 메일에 다음과 같은 악성 instruction이 포함되어 있다.

- 메일 내용을 외부 주소로 전송하도록 유도
- 공격자의 캘린더 또는 URL을 사용하도록 유도
- 원래 요청에 없던 tool을 호출하도록 유도
- 사용자의 메일이나 다른 민감정보를 추가도 조회하도록 유도
- Human approval 없이 외부 action을 실행하도록 유도

메일 본문은 업무 데이터로서 읽어야 하지만, 시스템 권한을 지시할 수 있는 trusted instruction은 아니다. 따라서 검색된 메일의 데이터가 model decision은 거쳐 권한 있는 action으로 전환되는 지점이 핵심 trust boundary가 된다.

4.3 주요 자산과 Trust Boundary

구분	내용
보호 자산	메일 본문, 개인정보, 인증정보, 캘린더, 외부 전송 권한, 실행 도구
비신뢰 입력	외부 발신자가 작성한 메일과 첨부·링크
고권한 기능	메일 추가 조회, 외부 전송, 캘린더 생성·수정, 외부 API 호출
주요 boundary	메일→context, model output→action candidate, action candidate→tool execution
주요 위협	Indirect prompt injection, excessive agency, privilege misuse, data exfiltration
주요 영향	개인정보 유출, 비인가 action, 업무 운영 피해, 금전·평판 손실

5. Use Case 기반 AI RMF Target Profile

이 Profile은 NIST가 제공한 공식 Profile이 아니라, AI RMF Core에서 해당 use case에 필요한 outcome을 선택하여 구체화한 **use-case Target Profile**이다.

GOVERN은 판단 기준을 정하고, MAP은 그 기준으로 위험 위치를 찾고, MEASURE는 위험의 크기와 control 효과를 검증하며, MANAGE는 결과에 따라 위험을 처리하고 지속해서 추적한다.

✔ GOVERN establishes the decision criteria, MAP identifies where risks arise based on those criteria, MEASURE evaluates the magnitude of the risks and the effectiveness of controls, and MANAGE treats and continuously tracks the risks based on the results.

Function	이 Use case의 예	핵심 질문
----------	---------------	-------

GOVERN	외부 메일 내용만으로 calendar event를 생성 LG GRC i? 못하도록 하고, 참석자 초대·외부 링크 등에는 사용자 승인이 필요하다는 policy와 책임자를 정한다.	어떤 원칙과 책임으로 관리할 것인가?
MAP	외부 메일이 un pencils trusted data도 model context에 들어가고, model output이 calendar write action으로 전환되는 boundary에서 prompt injection 위험이 발생한다고 식별한다.	어디에서 어떤 위험이 발생하는가?
MEASURE	악성 지시가 포함된 test email 100건을 실행하여, 승인 없이 calendar action이 생성된 비율을 측정한다.	위험이 실제로 얼마나 발생하는가?
MANAGE	측정 결과 무단 실행이 발견되면 외부 메일 기반 calendar write를 REQUIRE_APPROVAL도 동제하고, 배포 후 우회 발생률은 monitoring한다.	측정된 위험은 어떻게 처리하고 추적할 것인가?

GOVERN
" action ."

MAP
" model context calendar write ."

MEASURE
" 100 action ?"

MANAGE
"REQUIRE_APPROVAL monitoring."

GOVERN
policy .

5.1 GOVERN Profile

Core ID	적용 목표	필요한 구현·증적
GOVERN 1.1	이메일·캘린더·개인정보 처리와 외부 model/provider 사용에 적용되는 법률 및 규제 요구사항을 식별한다.	법률·규제 요구사항 목록, privacy review, provider assessment
GOVERN 1.2	Trustworthy AI 특성은 제품 정책과 개발·배포 절차에 통합한다.	Security/privacy requirement, release criteria, review checklist
GOVERN 1.3	Use case의 위험 수준에 따라 필요한 검토·시험·승인 수준을 결정한다.	Risk tier, human approval 기준, TEVV 수준
GOVERN 1.4	조직의 위험 우선순위에 따라 risk management process와 control을 수립한다.	Control objective, risk-treatment decision, exception 기준
GOVERN 1.5	운영 모니터링과 정기 검토의 책임 및 빈도를 정의한다.	Control owner, monitoring owner, review schedule
GOVERN 1.6	AI assistant, model, provider, tool 및 배포 정보를 inventory도 관리한다.	AI inventory, model/provider version, data type, owner, approval status
GOVERN 2.1	Policy Owner, Implementation Owner, Assurance Owner와 Risk Owner의 책임을 구분한다.	RACI, approval authority, escalation path
GOVERN 2.3	개발·배포 및 residual risk에 대한 경영진 책임을 명확히 한다.	Go/no-go 승인, exception/risk acceptance record
GOVERN 4.2	시스템 위험과 잠재적 영향은 문서화하고 관련 조직과 공유한다.	Threat model, assessment report, residual risk
GOVERN 4.3	시험, incident 식별 및 정보 공유 체계를 수립한다.	Security test, incident criteria, reporting process
GOVERN 6.1	Model provider, email/calendar API와 기타 제3자 위험을 관리한다.	Provider assessment, data-use/retention terms, SLA
GOVERN 6.2	제3자 model/API failure 또는 incident에 대한 비상 프로세스를 마련한다.	Provider outage plan, credential revoke, fallback 및 shutdown 절차

5.2 MAP Profile

Core ID	적용 목표	Use case 적용 결과
MAP 1.1	Intended use와 예상 배포환경은 정의한다.	승인된 메일 검색·요약·캘린더 등등만 허용
MAP 1.3	조직의 목표를 정의한다.	업무 생산성 향상과 비인가 정보 접근·action 방지
MAP 1.4	AI를 사용하는 비즈니스 가치를 정의한다.	반복적인 검색·요약·일정 등록 시간 절감
MAP 1.5	Risk tolerance를 정의한다.	비인가 외부 전송과 권한 확대는 허용하지 않음
MAP 1.6	시스템 요구사항을 도출한다.	메일 본문은 instruction authority를 갖지 않으며, tool action은 별도 authorization을 거쳐야 함
MAP 2.1	시스템이 수행하는 작업은 정의한다.	Search, retrieve, summarize, propose calendar event, create event
MAP 2.2	지식 한계와 human oversight를 문서화한다.	Model은 메일의 업무 데이터와 악성 instruction을 완벽하게 구분할 수 없음
MAP 3.2	오류와 실패의 잠재적 비용을 식별한다.	정보유출, 잘못된 일정, 업무 방해, 평판 피해
MAP 3.3	적용 범위를 제한한다.	승인된 mailbox, calendar, recipient와 tool만 접근
MAP 3.5	Human oversight를 정의한다.	외부 전송·새 수신자·고위험 action에는 사용자 승인 필요
MAP 4.1	제3자 data·software의 기술적·법적 위험은 매핑한다.	Model provider, email API, calendar API와 cross-border data flow
MAP 4.2	내부 동제를 식별한다.	Least privilege, token scope, policy engine, parameter validation, logging
MAP 5.1	영향의 가능성과 크기를 식별한다.	개인정보 유출과 비인가 action의 likelihood/impact 평가
MAP 5.2	사용자와 영향을 받는 actor의 피드백을 반영한다.	오탐·누락·비인가 action 신고 및 appeal mechanism

5.3 MEASURE Profile

Core ID	Validation Criteria	Test/Evidence
MEASURE 1.1	가장 중대한 위험부터 측정하고, 측정할 수 없는 위험은 문서화한다.	Indirect prompt injection과 비인가 action을 최우선 시험
MEASURE 1.2	지표와 통제 효과성은 정기적으로 재평가한다.	Attack success rate, false allow, false deny, approval rate
MEASURE 1.3	개발자와 분리된 내부 전문가 또는 독립 평가자가 검토한다.	Security review, independent test result
MEASURE 2.1	Test set, metric과 TEVV 도구를 문서화한다.	정상·악성 메일 corpus, test case, expected decision
MEASURE 2.3	실제 배포환경과 유사한 조건에서 성능 및 보증 기준을 측정한다.	실제 tool schema와 권한은 사용한 staging test
MEASURE 2.4	운영 중 시스템 기능과 행동을 모니터링한다.	Tool invocation, parameter, authorization decision log
MEASURE 2.5	정상 use case에서 유효하고 신뢰할 수 있음을 입증한다.	정상 메일 검색·요약·캘린더 등등 성공률
MEASURE 2.6	안전하게 실패하고 residual risk가 tolerance를 넘지 않음을 확인한다.	Policy unavailable 시 default deny, timeout과 fallback test
MEASURE 2.7	Security와 resilience를 평가한다.	Prompt injection, privilege escalation, token misuse test
MEASURE 2.8	Transparency와 accountability 위험을 평가한다.	Decision owner와 action reason을 사후 추적할 수 있는지 확인
MEASURE 2.9	Model과 output을 설명·검증·문서화한다.	Action candidate와 실제 tool execution의 연결 기록
MEASURE 2.10	Privacy risk를 평가한다.	Model/provider에 전달된 개인정보, masking/tokenization 결과
MEASURE 3.1	운영 중 기존·예상하지 못한·새로운 위험을 추적한다.	Incident trend, new injection pattern, model version별 회귀
MEASURE 3.3	사용자가 문제를 신고하고 결과에 이익을 제기할 수 있게 한다.	Feedback, cancel/undo, incident report
MEASURE 4.2	시스템이 의도한 대로 일관되게 작동하는지 확인한다.	주기적 regression test와 field evidence

5.4 MANAGE Profile

Core ID	관리 결정	적용 방법
MANAGE 1.1	Intended purpose를 충족하고 배포를 진행할 수 있는지 판단한다.	Release criteria 기반 go/no-go

MANAGE 1.2	Impact, likelihood 및 자원에 따라 위험 처리 우선순위를 정한다.	비인가 외부 전송과 개인정보 유출은 최우선 처리
MANAGE 1.3	고위험 항목의 대응은 수립한다.	Mitigate, transfer, avoid 또는 accept 결정
MANAGE 1.4	동제 후 남은 residual risk를 문서화한다.	알려지지 않은 injection, contextual re-identification 등 기록
MANAGE 2.1	AI 대안과 필요한 자원을 함께 고려한다.	고위험 action은 non-AI workflow 또는 수동 승인 사용
MANAGE 2.3	알려지지 않았던 위험 발견 시 대응·복구한다.	Policy update, credential revoke, affected action 취소
MANAGE 2.4	의도된 사용과 다른 행동을 보이는 시스템을 중단할 수 있게 한다.	Kill switch, tool disable, model rollback
MANAGE 3.1	제3자 provider 위험과 동제를 지속해서 모니터링한다.	Provider policy-retention-region-model 변경 검토
MANAGE 3.2	Pre-trained model을 정기 모니터링 대상으로 포함한다.	Model version change와 security regression
MANAGE 4. verlie	배포 후 모니터링·appeal·override·incident response·change management를 수행한다.	Monitoring plan, approval log, incident runbook
MANAGE 4.2	측정 가능한 지속적 개선 환동은 시스템 업데이트에 반영한다.	Test coverage와 attack-blocking 성능 추세
MANAGE 4.3	Incident와 error를 관련 actor에게 알리고 대응·복구 과정을 문서화한다.	Incident record, notification, recovery evidence

정정: 위 표의 MANAGE 4. verlie는 MANAGE 4.1을 의미한다.

6. Target Control Architecture

Identity Session Context

Email Search/Retrieval

.

Prompt/Context Builder

Model

Action Candidate

Schema Parameter Validation

Policy Decision Point

ALLOW

DENY

REQUIRE_APPROVAL

Policy Enforcement Point

Email/Calendar Tool

Execution Evidence Monitoring

동제 원칙

Model proposes. Harness authorizes. Policy decides. Guardrail enforces. Evidence proves.

계층	책임
Model	사용자 요청과 데이터를 바탕으로 action candidate를 제안한다.
Harness	Model output을 구조화하고 실행 가능한 action인지 확인한다.

Policy	Identity, tool, resource, parameter 및 context를 기반으로 실행 여부를 결정한다.
Guardrail/PEP	정책 결정은 runtime에 집행한다.
Evidence	Input, context, policy version, decision, approval과 실행 결과를 연결하여 기록한다.

7. 주요 Validation Criteria와 Evidence

Control Objective	Validation Criteria	Required Evidence
메일 본문의 instruction이 시스템 권한을 변경하지 못하게 한다.	악성 instruction이 포함된 메일이 추가 tool 권한이나 외부 전송을 발생시키지 않는다.	공격 test result, action trace, final decision
모든 tool action을 독립적으로도 authorization 한다.	Model이 생성한 action은 policy evaluation 없이 실행되지 않는다.	Gateway log, policy decision, execution log
고위험 action에는 human approval을 요구한다.	외부 전송, 신규 수신자 및 민감정보 포함 action은 승인 전 실행되지 않는다.	Approval request, approver identity, timestamp
최소권한을 적용한다.	Agent는 승인된 mailbox, calendar, tool과 action에만 접근한다.	IAM/OAuth scope, access policy, negative test
개인정보 전달을 최소화한다.	Model/provider에는 작업 수행에 필요한 최소 데이터만 전달된다.	Data-flow diagram, request log, masking /tokenization result
실행 과정을 사후 추적할 수 있다.	Source-decision-policy-approval-action 관계를 동일 run에서 연결할 수 있다.	Run ID, source reference, policy version, action evidence
동제 변경 후 회귀를 방지한다.	Policy와 model 변경 후 기존 정상-공격 test가 반복 수행된다.	Versioned test suite, regression report

8. Residual Risk

동제를 적용하더라도 다음 위험은 남을 수 있다.

- 알려지지 않은 indirect prompt injection 방식
- 정상 업무 instruction과 악성 instruction 간의 의미적 모호성
- 허용된 tool의 조합을 이용한 예상하지 못한 action chain
- 사용자가 악성 action을 승인하는 문제
- Model 또는 provider 변경에 따른 동작 변화
- 도그에 reasoning과 실제 영향 관계가 충분히 보존되지 않는 문제
- Tokenization 후에도 다른 속성 조합으로 개인을 추론하는 contextual re-identification
- Gateway 또는 PEP를 우회하는 별도 tool invocation path

Residual risk는 단순히 기록하는 데 그치지 않고 다음과 연결해야 한다.

Residual Risk
Risk Owner
Acceptance/Remediation Decision

Trigger

9. 핵심 정리

NIST AI RMF Core는 구체적인 AI 보안 제품이나 동제를 지정하지 않는다. 조직이 달성해야 할 risk management outcome은 GOVERN, MAP, MEASURE, MANAGE로 정의한다.

본 use case에서는 이를 다음과 같이 적용할 수 있다.

GOVERN

, , risk tolerance, inventory third-party

MAP

, model, tool, actor, trust boundary

MEASURE

Indirect prompt injection, action TEVV

MANAGE

Go/no-go, , residual risk, monitoring incident response

핵심은 model의 판단과 실행 권한을 분리하는 것이다. AI assistant가 action을 제안할 수는 있지만, 실제 tool 실행은 별도의 deterministic authorization, runtime enforcement 및 evidence 체계를 통과해야 한다.